第 9 章 公钥密码学与RSA

0. 学习目标总览

教材给出本章六个学习目标：

1. 概述公钥密码体制的基本原理。
2. 阐述公钥密码体制的两个不同应用。
3. 列举和解释公钥密码体制的要求。
4. 概述RSA算法。
5. 理解计时攻击。
6. 总结算法复杂性的相关问题。

公钥密码学是密码学发展史上最伟大的一次革命。不同于传统密码基于代替和置换，公钥密码基于数学函数，且使用两个独立密钥——不仅可用于保密性，在密钥分发和认证领域也有重要意义。RSA 是最早满足公钥体制全部要求的算法之一，至今仍是最广泛使用的公钥加密方法。

```
公钥密码学
  |
  ├── 公钥密码体制的原理
  |      ├── 六要素：明文、密文、公钥、私钥、加密算法、解密算法
  |      ├── 保密性：发送方用接收方公钥加密
  |      ├── 认证性：发送方用自己私钥签名
  |      `-- 密钥交换：双方交换会话密钥
  |
  ├── 三种应用
  |      ├── 加密/解密
  |      ├── 数字签名
  |      `-- 密钥交换
  |
  ├── 公钥密码的要求：单向陷门函数
  |
  `-- RSA 算法
         ├── 密钥生成：p, q, n=pq, ϕ(n), e, d
         ├── 加密：C = M^e mod n
         ├── 解密：M = C^d mod n
         ├── 计算问题：模幂运算、CRT加速、密钥生成
         `-- 安全性：因子分解、计时攻击、CCA、OAEP
```

1. 学习目标 1：公钥密码体制的基本原理

1.1 对称密码面临的两个难题

公钥密码学为解决对称密码中最困难的两个问题而提出：

1. **密钥分发**：对称密码要求通信双方已共享密钥（通过某种途径分发），或依赖密钥分发中心（KDC）。Diffie 认为后者有悖于密码学"在通信过程中完全保持保密性"的精髓。

2. **数字签名**：公钥密码中可用私钥签名、用公钥验证，提供了对称密码难以自然实现的功能。

1.2 公钥密码体制的六要素

教材定义公钥密码体制由以下六个要素组成：

要素	说明
明文	可读的消息或数据，作为算法的输入。
加密算法	对明文进行各种变换。
公钥和私钥	一对密钥，一个用于加密则另一个用于解密；从一个推出另一个在计算上不可行。
密文	作为输出的置乱消息，取决于明文和密钥；对给定消息，不同密钥产生不同的密文。
解密算法	接收密文和相应密钥，恢复原始明文。

1.3 公钥密码的三个纠正误解

教材指出了三种常见误解：

1. **公钥密码比传统密码更安全**——任何加密方法的安全性都取决于密钥长度和破译所需的计算量，不能说哪种体制原则上更安全。
2. **公钥密码已使传统密码过时**——由于公钥密码计算量大，传统密码不可能被抛弃。公钥密码仅限用于密钥管理和签名。
3. **公钥密码中密钥分发非常简单**——实际仍需某种形式的协议，通常包含中心代理，过程并不比传统密码简单或更有效。

1.4 保密性和认证性

公钥体制可提供保密性和认证性（即数字签名）：

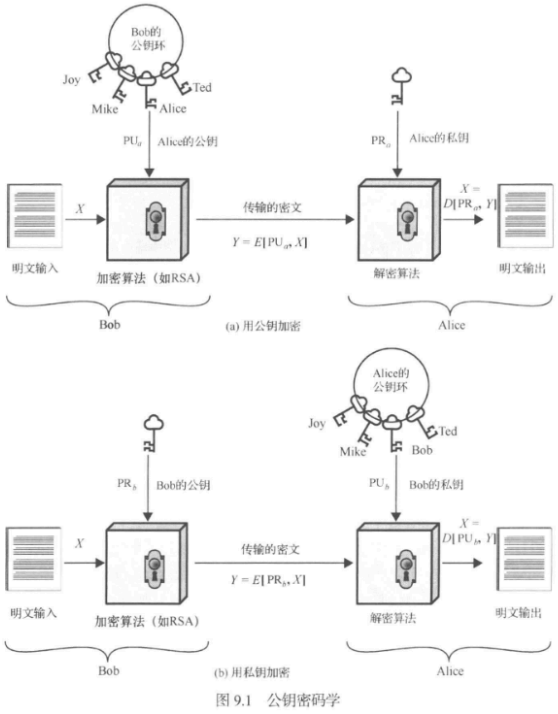


图 9.1　公钥密码学

图 9.1 公钥密码体制：保密性与认证

在保密性应用中，发送方使用接收方的公钥加密，只有接收方可用其私钥解密：

$$C = E(PU_b, M), \qquad M = D(PR_b, C)$$

在认证应用中，发送方用其私钥"签名"，任何人可用发送方的公钥验证：

$$C = E(PR_a, M), \qquad M = D(PU_a, C)$$

2. 学习目标 2：公钥密码的三种应用

表 9.3 列出本书讨论的算法及其支持的应用：

算法	加密/解密	数字签名	密钥交换
RSA	是	是	是
椭圆曲线	是	是	是
Diffie-Hellman	否	否	是
DSS	否	是	否

加密/解密： 发送方用接收方公钥加密，接收方用自己私钥解密。没有人能解密。

数字签名： 发送方用自己的私钥"签署"消息（实际是对**哈希值**加密签名）。接收方可用发送方的公钥验证签名。

密钥交换： 通信双方交换会话密钥，使用一方或双方的私钥。例如 Diffie-Hellman 允许两方协作建立共享密钥而不需事先共享的秘密。

3. 学习目标 3：公钥密码的要求——单向陷门函数

3.1 六项条件

Diffie 和 Hellman 提出了公钥密码体制必须满足的条件：

1. 产生一对密钥 (PU_b, PR_b) 在计算上容易。
2. 已知 PU_b 和消息 M，计算 $C = E(PU_b, M)$ 在计算上容易。
3. 已知 PR_b，解密 $M = D(PR_b, C)$ 在计算上容易。
4. 已知 PU_b 时，确定 PR_b 在计算上不可行。
5. 已知 PU_b 和 C 时，恢复 M 在计算上不可行。
6. （可选但有用）两个密钥顺序可交换：$M = D[PU_b, E(PR_b, M)] = D[PR_b, E(PU_b, M)]$。

3.2 单向函数与单向陷门函数

单向函数满足每个函数值存在唯一逆，计算函数值容易，但求逆不可行：

$$Y = f(X) \text{ 容易}; \qquad X = f^{-1}(Y) \text{ 不可行}$$

单向陷门函数是一类不可逆函数 f_k，满足：

- 若 k 和 X 已知，$Y = f_k(X)$ 容易计算；（正向高效性）
- 若 k 和 Y 已知，$X = f_k^{-1}(Y)$ 容易计算；（带陷门的逆向高效性）
- 若 Y 已知但 k 未知，$X = f_k^{-1}(Y)$ 在计算上不可行。（无陷门的逆向不可行性）

寻找合适的单向陷门函数是公钥密码体制应用的关键。只有少数算法（RSA、椭圆曲线密码学、Diffie-Hellman、DSS）被普遍接受。

3.3 计算复杂性与密码学的关系

"容易"指可在输入长度的多项式时间内解决（P 类算法）。"不可行"指所需时间比多项式时间增长更快（如与 2^n 成正比）。但密码学不同于传统复杂性理论：它要求**对任何输入**都不能求出函数的逆，而不仅仅是最坏情况或平均情况不可逆。

4. 学习目标 4：RSA 算法

4.1 算法描述

RSA 是第一个满足公钥体制全部要求的算法（Rivest、Shamir、Adleman，1977 年）。对明文分组 M 和密文分组 C：

$$C = M^e \bmod n, \qquad M = C^d \bmod n = (M^e)^d \bmod n = M^{ed} \bmod n$$

公钥为 $\{e, n\}$，私钥为 $\{d, n\}$。

算法元素：

元素	说明	状态
p, q	两个大素数	保密，选定
$n = pq$	模数	公开，计算得出
$\phi(n) = (p-1)(q-1)$	欧拉函数	保密
e	满足 $\gcd(\phi(n), e) = 1, 1 < e < \phi(n)$	公开，选定
$d \equiv e^{-1} \pmod{\phi(n)}$	e 模 $\phi(n)$ 的乘法逆元	保密，计算得出

为什么是 φ(n) 而不是 n?

因为 e 和 d 是在“指数运算”的层面上互为逆元，而这个运算所在的代数结构是模 $\phi(n)$ 的同余类，而不是模 n 的同余类。
详见下图

RSA算法的解密正确性依赖于以下同余式：

$$M^{ed} \equiv M \pmod{n}$$

为了使得上述关系对于所有 $M < n$ 成立，RSA的构造要求指数 e 和 d 满足：

$$ed \equiv 1 \pmod{\phi(n)}$$

其中 $\phi(n) = (p-1)(q-1)$。也就是说，e 和 d 在模 $\phi(n)$ 的意义下互为乘法逆元。

第二，数论定理：线性同余方程有解的充要条件

现在考察同余式 $ed \equiv 1 \pmod{\phi(n)}$。将其改写为线性方程：

$$ed - k \cdot \phi(n) = 1$$

这是一个关于未知整数 d 和 k 的二元一次不定方程。根据初等数论中的线性同余方程解的存在定理（亦称裴蜀定理），该方程存在整数解的**充要条件**是：

$$\gcd(e, \phi(n)) \mid 1$$

由于 1 只能被 1 整除，因此必须有：

$$\gcd(e, \phi(n)) = 1$$

也就是说，如果 e 与 $\phi(n)$ 不互素，那么 d 在整数范围内根本不存在，加密后的密文无法通过任何整数指数解回明文。

Alice 生成密钥	
选择 p, q	p 和 q 都是素数，$p \neq q$
计算 $n = p \times q$	
计算 $\phi(n) = (p-1)(q-1)$	
选择整数 e	$\gcd(\phi(n), e) = 1;\ 1 < e < \phi(n)$
计算 d	$d \equiv e^{-1} \pmod{\phi(n)}$
公钥	PU = $\{e, n\}$
私钥	PR = $\{d, n\}$

Bob 使用 Alice 的公钥加密	
明文	$M < n$
密文	$C = M^e \bmod n$

Alice 使用自己的私钥解密	
密文	C
明文	$M = C^d \bmod n$

图 9.5　RSA 算法

图 9.5 RSA 算法

核心数学关系： $M^{ed} \bmod n = M$ 成立，当 $ed \equiv 1 \pmod{\phi(n)}$，即 e 和 d 互为模 $\phi(n)$ 的乘法逆元。

教材示例：

步骤	计算
选素数	$p = 17,\ q = 11$
模数	$n = 17 \times 11 = 187$
欧拉函数	$\phi(n) = 16 \times 10 = 160$
选 e	$e = 7$（与 160 互素）
计算 d	$d = 23$（因为 $23 \times 7 = 161 = 1 \times 160 + 1$）
公钥	$\{7, 187\}$
私钥	$\{23, 187\}$

加密 $M = 88$：$C = 88^7 \bmod 187 = 11$。
解密 $C = 11$：$M = 11^{23} \bmod 187 = 88$。

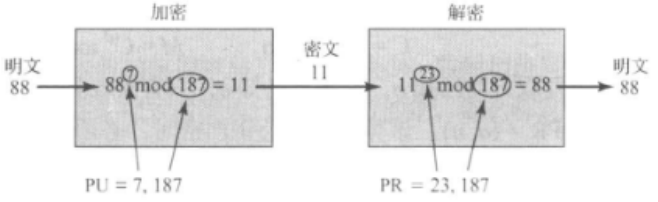
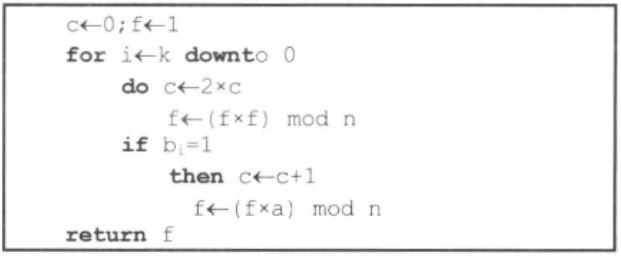


图 9.6　RSA 算法示例

图 9.6 RSA 算法示例

4.2 计算问题

模幂运算（快速幂）。 $M^e \bmod n$ 可通过"平方-乘"算法高效完成：将指数逐位扫描，每步平方，遇 1 则再乘以底数。教材例中以 $a=7$、$b=560=1000110000$ 演示：a^{560} 只需 9 次模乘。



注：整数 b 表示为二进制数 $b_k b_{k-1} \cdots b_0$

图 9.8　计算 $a^b \bmod n$ 的算法

图 9.8 快速幂算法

> 快速幂算法中，模幂运算是逐位实现的，每次迭代都执行一次模乘运算（更新模乘数），该位为一时还需要再执行一次模乘运算（计入结果）

使用 CRT 加速解密。 利用中国剩余定理（CRT）可将解密速度提升约 4 倍：

$$V_p = C^d \bmod p, \qquad V_q = C^d \bmod q$$

$$\Rightarrow V_p = C^{d \bmod (p-1)} \bmod p, \qquad V_q = C^{d \bmod (q-1)} \bmod q$$

$$X_p = q \times (q^{-1} \bmod p), \qquad X_q = p \times (p^{-1} \bmod q)$$

$$M = (V_p X_p + V_q X_q) \bmod n$$

> 由于 RSA 解密是在大整数上进行模幂运算，且由于 $n = p \cdot q$，且两仅为 n 的一半长度，中国剩余定理提供了一条捷径：**不在 n 下直接计算，而是分别在 p 和 q 下独立计算，最后将两个结果拼接回模 n 下的结果。** 于是有了第一步。
> 这里 V_p 表示明文 M 在模 p 下的剩余类，V_q 表示明文 M 在模 q 下的剩余类。由于 p, q 为素数，实际计算时可以用费马小定理将指数 d 缩小为 $dmod(p-1)$ 和 $dmod(q-1)$，使得运算量大幅降低。
> 接着运用中国剩余定理给出的构造公式： $M = V_p \cdot X_p + V_q \cdot X_q (mod n)$，其中 X_p 和 X_q 是预先计算好的固定系数，其设计目标分别是：① X_p 的作用：当只取模 p 的时，X_p 应为 1，而当取模 q 时，X_p 应为 0；② X_q 的作用：当只取模 q 的时，X_q 应为 1，而当取模 p 时，X_q 应为 0。

密钥生成。 随机选择期望大小的奇数，用概率素性测试（如 Miller-Rabin）检测其是否为素数；若不通过则重选。由素数定理知，在 N 附近每 $\ln N$ 个整数中就有一个素数，故实际仅需测试约 $\ln(N)/2$ 次。

确定 p, q 后，选择满足 $\gcd(\phi(n), e) = 1$ 的 e（通常选小值如 65537），再用扩展欧几里得算法计算 $d \equiv e^{-1} \pmod{\phi(n)}$。两个随机数互素的概率约为 0.6，因此找到合适 e 所需测试次数非常少。

5. 学习目标 5：计时攻击

5.1 基本原理

计时攻击由 Kocher 提出：敌手通过记录计算机解密消息所用的时间来确定私钥。该攻击利用模幂算法中"遇 1 位则多一步乘法"的运行时间差异。

类似于窃贼通过观察他人转动保险柜拨号盘的时间长短来猜测密码，我们可以通过图 9.8 中的模拟算法来说明这种攻击。

5.2 三种防御方法

方法	说明	性能影响
不变幂运算时间	保证所有幂运算在返回结果前执行相同时间。	降低性能
随机延时	在幂运算中加入随机延时迷惑攻击。	若噪声不足，敌手可通过更多观察抵消。
隐蔽（blinding）	幂运算前将密文乘以随机数 r，使敌手不知道正在处理的是哪些位。	性能降低 $2\% \sim 10\%$

隐蔽方法的具体步骤：

1. 生成随机数 r（$0 < r < n$）；
2. 计算 $C' = C(r^e) \bmod n$；
3. 计算 $M' = (C')^d \bmod n$；
4. 计算 $M = M' r^{-1} \bmod n$。

6. RSA 的安全性：因子分解、选择密文与 OAEP

6.1 因子分解问题

针对 RSA 的数学攻击有三种途径：分解 n 为两个素因子、直接确定 $\phi(n)$、直接确定 d。这三种途径在计算上等价于因子分解 n，因此因子分解的性能是评价 RSA 安全性的基准。

因子分解的进展与密钥建议：

里程碑	年份	密钥长度
RSA 发明者预测	1977	129 位十进制需 4×10^{16} 年
实际攻破	1994	129 位十进制，8 个月
RSA-768 分解	2010	768 位二进制

机构	建议
NIST SP 800-131A（2015）	2048 位或更长
欧盟网络信息安全局（2014）	3072 位或更长
加拿大通信安全机构（2016）	至少 2048 位，2030 年前升至 3072 位

p 和 q 的额外约束：

1. p 和 q 长度仅相差几位；
2. $p-1$ 和 $q-1$ 都应有一个大的素因子；
3. $\gcd(p-1, q-1)$ 应该较小；
4. 若 $e < n$ 且 $d < n^{1/4}$，d 很容易被确定。

6.2 选择密文攻击（CCA）

RSA 的乘法性质使基本 RSA 易受选择密文攻击：

$$E(PU, M_1) \times E(PU, M_2) = E(PU, [M_1 \times M_2]) \tag{9.2}$$

简单 CCA 示例：为解密 $C = M^e \bmod n$，

1. 计算 $X = (C \times 2^e) \bmod n = (2M)^e \bmod n$；
2. 提交 X 并收到 $Y = X^d \bmod n = 2M \bmod n$；
3. 由此得到 M。

简单的随机填充不足以防御更复杂的 CCA，因此推荐使用 **最优非对称加密填充（OAEP）**：在 RSA 加密前，将消息通过哈希函数和随机种子进行掩蔽，使密文随机化，破坏 RSA 的乘法性质。

对于 OAEP，第一步，填充待加密的消息 M。可选参数集 P 作为哈希函数 H 的输入，输出用 0 加以填充以获得期望的长度，从而放入整个数据块 DB。接着，随机选择一个种子，并作为一个哈希函数的输入，该哈希函数称为掩码生成函数（MGF）。输出哈希值和 DB 按位异或，生成掩码 DB（maskedDB）。maskedDB 反过来又作为 MGF 的输入生成一个哈希值，哈希值和种子进行异或，生成掩码种子。掩码种子和掩码 DB 连接后构成编码后的消息 EM。注意，EM 包含填充后的消息，该消息由种子掩蔽，而种子又由 maskedDB 掩蔽。最后用 RSA 对整个 EM 加密。

> OAEP 将确定性的 RSA 基本算法提升为具有可证明安全性的概率加密体制。

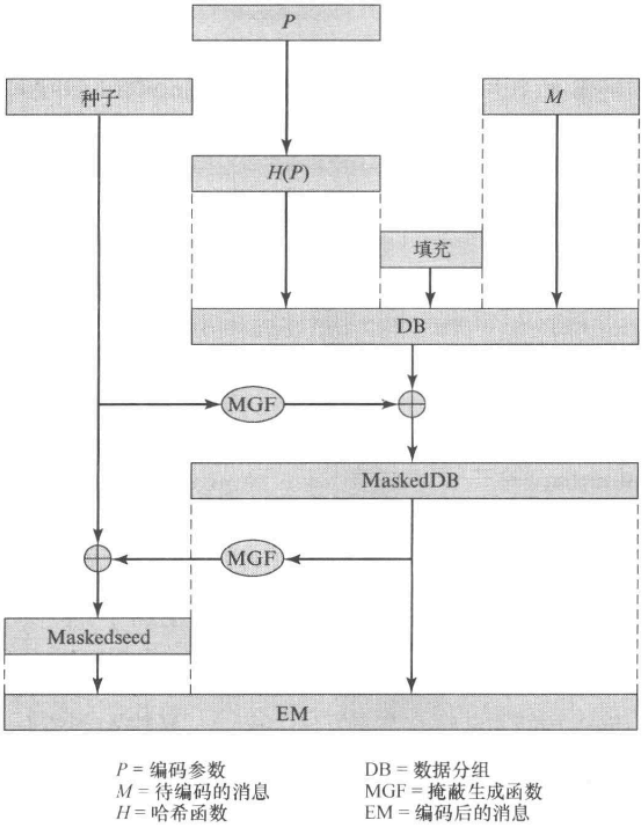


图 9.9 使用 OAEP 加密

本章关键术语整理

术语	教材含义
公钥密码	使用两个密钥（公钥和私钥）的密码体制。
公钥	非对称密码系统中可公开使用的密钥。
私钥	非对称密码系统中由单一用户保有的密钥。
单向函数	计算值容易但求逆不可行的函数。
单向陷门函数	已知附加信息（陷门）时可在多项式时间内求逆的单向函数。
RSA	基于大整数因子分解困难性的公钥加密算法。
中国剩余定理（CRT）	将模 n 运算拆为模 p 和模 q 运算以加速 RSA 解密。
计时攻击	通过记录解密时间来推导私钥的攻击方式。
选择密文攻击（CCA）	敌手选择密文并得到对应明文，利用这些信息进行密码分析。
OAEP	最优非对称加密填充，加密前随机化明文以防御 CCA。

学习目标自检

1. 能说明公钥密码体制六要素，并解释保密性和认证两种应用模式中各使用哪一方的密钥。
2. 能区分加密/解密、数字签名、密钥交换三类应用，并举例说明各支持哪些算法。
3. 能完整陈述公钥密码六项要求，从而推出一对密钥的本质就是一个单向陷门函数。
4. 能写出 RSA 的公钥构造：$n = pq$, $\phi(n) = (p-1)(q-1)$, $ed \equiv 1 \pmod{\phi(n)}$，并解释为何正确。
5. 能说明快速模幂、用 CRT 加速解密（约 4 倍）、概率素性测试和扩展欧几里得算法在 RSA 中的角色。
6. 能解释计时攻击如何利用幂运算中的条件分支，以及不变时间、随机延时和隐蔽三种防御策略。
7. 能说明 RSA 安全性建立在因子分解困难性的基础之上，并清楚 2010 年后对密钥长度的升级建议和 p, q 的选择限制。
8. 能解释 RSA 的乘法性质如何导致选择密文攻击，以及 OAEP 如何通过哈希和随机种子打破该性质。